

NEWSLETTER N. 511 of October 10, 2023

Healthcare: Privacy Authority's Ten Commandments on the Use of Artificial Intelligence

Telecommunications: SIM cards registered to an unaware user, the Authority fines a company 90,000 euros

Labor: the employee has the right to access geolocation data

Healthcare: Privacy Authority's Ten Commandments on the Use of Artificial Intelligence

The Privacy Authority has established a ten-point guideline for the implementation of healthcare services at the national level through artificial intelligence (AI) systems. Transparency of decision-making processes, automated decisions supervised by humans, and algorithmic non-discrimination are the three cornerstone principles outlined by the Authority based on the Regulation and in light of the jurisprudence of the Council of State.

According to the Authority's guidelines, patients must have the right to know, including through communication campaigns, whether there are and what decision-making processes (for example, in clinical or health policy contexts) are based on automated treatments carried out through AI tools, and to receive clear information about the logic used to arrive at those decisions.

The decision-making process must include human oversight that allows healthcare personnel to check, validate, or refute the processing carried out by AI tools. It is advisable, the Authority warns, that the data controller uses reliable AI systems that reduce errors due to technological or human causes and periodically verifies their effectiveness, implementing appropriate technical and organizational measures. This is also aimed at mitigating potential discriminatory effects that the processing of inaccurate or incomplete data could have on a person's health. An example is the American case referenced by the Authority in the ten-point guideline, concerning an AI system used to estimate the health risk of over 200 million Americans. The algorithms tended to assign a lower risk level to African American patients under equal health conditions, due to the metric used, based on average individual healthcare spending, which was lower for the African American population, resulting in denying them access to adequate care.

The outdated or inaccurate data, the Authority emphasizes, could also affect the effectiveness and correctness of the services that AI systems intend to provide. Particular attention has been given by the Authority to the suitability of the legal basis for the use of artificial intelligence. The processing of health data through AI techniques, carried out for public interest reasons in the healthcare sector, must be provided for by a specific regulatory framework that identifies adequate measures to protect the rights, freedoms, and legitimate interests of the data subjects.

In compliance with the sector regulatory framework, the Authority also emphasized the need for an impact assessment to be conducted before processing health data through national AI systems, in order to identify suitable measures to protect the rights and freedoms of patients and ensure compliance with the principles of the EU Regulation. A centralized national system that uses AI indeed results in systematic large-scale processing of health data that falls into the "high-risk" category, for which an impact assessment is mandatory and must be conducted at the central level to allow for a comprehensive examination of the adequacy and uniformity of the measures adopted.

In the description of the treatments, it is also necessary to specifically indicate, in particular, the algorithmic logics used to "generate" the data and services, the metrics employed to train the model, the checks carried out to verify the presence of any biases, and the possibility of their correction. The Ten Commandments are available on the website www.gpdp.it

Telecommunications: SIM cards registered to an unaware user, the Authority fines a company 90,000 euros

An individual receives two emails and a notification SMS from a telecommunications company and discovers that a retailer had activated two prepaid SIM cards in his name without his knowledge. This occurred to a user in the province of Bergamo who, after reporting the incident to the judicial authority, informed the Privacy Authority, which fined the telecommunications company's sales network, to which the retailer belongs, 90,000 euros for unlawful processing of personal data.

The affected individual, after requesting the blocking of the SIM cards from the telecommunications company and conducting some checks, had reconstructed that the cards had been activated in the Naples area using a barely legible photocopy of his identity card. He also discovered that, for the charges of the two accounts, a non-existent IBAN had been entered, only formally correct, linked to a bank near his residence.

During the investigative activity, the Authority identified several violations. First of all, the retailer failed to identify the customer using an original identity document - a procedure correctly provided for by the telecommunications company's protocol - nor did it carry out further checks on the legality of the acquired data. Furthermore, the parent company of the retailer did not provide the Authority with the information and documents requested during the investigation, nor did it explain to the interested party how it obtained the photocopy of the identity card. The Guarantor, recognizing the seriousness and willful nature of the violations, deemed the conduct attributable to the phenomenon of the unlawful activation of telephone cards, which can also lead to crimes of an associative nature, and therefore imposed a fine of 90,000 euros on the company. No violations, however, emerged against the telecommunications company.

Work: the employee has the right to access geolocation data

*The measure has been appealed

The privacy Guarantor imposed a fine of 20,000 euros on a company responsible for reading gas, electricity, and water meters for failing to adequately respond to requests for access to data from three employees. The three workers, in order to verify the correctness of their paychecks, had asked the company to know the information used to process mileage reimbursements and hourly monthly wages, as well as the procedure for determining the compensation due.

In particular, they requested to know the data collected through the smartphone provided by the company, on which a geolocation system had been installed that allowed operators to identify the route to take to reach the meters. Having not received a satisfactory response from their then employer, they turned to the privacy Guarantor with a complaint.

During the investigation, the Authority established that the company, as the data controller, had not provided an adequate response to what was requested by the complainants, despite the clarity and detail of the requests, among other things not communicating to them the data processed through GPS. In fact, the company had limited itself to indicating the methods and purposes for which the data were processed. This conduct was deemed unlawful based on the principles of privacy legislation. From the GPS detection, in fact, as emphasized by the privacy Guarantor, the geolocation of employees indirectly derives, and consequently, a processing of personal data, at least at the time of reading the meters. The Guarantor therefore ordered the company to provide the complainants with the data relating to the specific readings/geographical coordinates obtained with the smartphone's GPS and all the information related to the requested processing. The Guarantor finally specified that the company, even if it did not believe it could fully respond to the employees' requests, should have at least indicated the specific reasons for which it could not satisfy the access requests, reminding the interested party of the right to file a complaint with the Guarantor or to seek judicial review.

NEWSLETTER of the Guarantor for the protection of personal data (Reg. at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Management and editorial office: Guarantor for the protection of personal data, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it